
Changelog — 2026-05-15

Two cuts of the same release: one for users, one for the team.

For users (public release notes)

What's new

- **Phone enrollment in Settings.** Add a verified phone number to your account so you can sign in by SMS OTP. Find it in **Settings** → **Phone number** → **Add phone number**.
- **Quicker recovery after app updates.** If you have Storey open in a browser tab when we ship a new version, you'll be moved to the new version automatically the next time you click a link, instead of seeing a blank page.

What's improved

- **SMS OTP sign-in is more secure.** We now lock SMS codes to your registered phone number and limit how many times a code can be guessed.
- **Clearer error messages** when sign-in fails or your profile can't load — including a Retry button when something goes wrong loading your account.
- **Multi-tab sign out works correctly.** Signing out in one tab now signs you out everywhere.
- **Better 404 page** when a link is wrong or out-of-date.

What you need to know

- If you sign in with **SMS OTP** and haven't enrolled a phone number yet, please **add your phone in Settings first**. Email/password and Google sign-in continue to work as before with no changes needed.
- **To change a phone number** that's already enrolled, please contact support.

What's coming next

- Cleaner inline hints for SMS OTP login if you haven't enrolled a phone yet.
 - Self-service phone change flow.
-

🔗 For the team (internal Slack post)

🚀 Auth & security hardening shipped — 2026-05-15

Live on prod (zgvgogxibiInblmuohg):

- 2 migrations applied: profile-field immutability trigger + bypass bridge for `Link_owner_to_tenant`
- 5 edge functions deployed: `send-sms-otp` (v14), `verify-sms-otp` (v22), `enroll-phone-otp` (v2 new), `verify-phone-enrollment` (v2 new), `register-tenant` (v2 new)

Closed 7 security/integrity holes:

1. 🔴 Privilege escalation — any user could `update({ role: 'superadmin' })` from console
2. 🔴 SMS OTP takeover — attacker who knew victim's email could overwrite their phone and log in
3. 🔴 OTP brute force — unlimited attempts on a 6-digit code
4. 🟠 Magic-link URL leaked in JSON response body
5. 🟠 User enumeration via "User not found" 400
6. 🟠 No server-side OTP rate limit
7. 🟡 Orphaned auth users when tenant insert failed post-signup

Plus app reliability fixes (in branch, awaiting merge): stale-chunk auto-reload after deploy, multi-tab signOut sync, StrictMode-safe auth init, surfaced profile-fetch errors, OAuth provider error handling, friendlier 404.

Verified live:

- ✅ Privilege escalation blocked (`UPDATE profiles SET role='superadmin' → exception`)
- ✅ Legitimate Google-OAuth contractor signup still works (tested via rollback'd txn)
- ✅ All 5 edge functions respond with expected status codes

Heads up:

- Users with `profiles.phone = NULL` who try SMS OTP login won't get an SMS until they enroll in Settings (silent UX — generic 200 response). Inline hint is the next follow-up.
- Edge functions changed contracts — `verify-sms-otp` now returns `token_hash` (not `magic_link`). Main's frontend falls into the "sign in with password" fallback after OTP verify until the frontend PR merges.

Branch: `claude/heuristic-kepler-947fd0` — 5 ahead, 43 behind main. Server side is live; merging this only ships the frontend polish.

Action items / open Qs:

- Add index: `phone_verifications(user_id, created_at DESC)` — prevents rate-limit query degradation at scale
- Decide: enforce email verification on signup? `register-tenant` currently sets `email_confirm: true`
- Audit `tenants` / `sites` / `pending_invites` / `budget_lines` RLS for the same `WITH CHECK` gap we fixed on `profiles`
- Frontend merge strategy for the 43-commit divergence

Reference:

- PRD: [docs/PRD-2026-05-15-auth-hardening.md](#)
- Commits on branch: [ad94ef3](#) , [bdba54f](#) , [4b16228](#) , [914f906](#) , [0ba5048](#) , [19cb2fe](#)